

DAY 21 ASSIGNMENT

Name:- Rishabh Raj

1. What does OWASP stand for?

OWASP stands for Open Worldwide Application Security Project. It is a global nonprofit community that provides knowledge, tools, standards, and guidance for improving software and web application security.

2. What is the purpose of the OWASP Top 10?

The OWASP Top 10 is an awareness document that highlights the most important and common web application security risks. It helps developers, testers, security teams, and organizations understand and reduce application security weaknesses.

3. Why is the OWASP Top 10 useful for cybersecurity engineers?

It provides a practical security baseline for identifying common application risks, prioritizing security testing, and applying suitable defensive controls. It also gives cybersecurity engineers a common language for discussing application security.

4. What is a vulnerability?

A vulnerability is a weakness or flaw in software, hardware, configuration, or a process that can be exploited by a threat actor to cause harm or gain unauthorized access.

5. What is a security risk?

Security risk is the possibility that a threat will exploit a vulnerability and cause damage, loss, unauthorized access, or disruption. Risk is commonly considered in terms of likelihood and impact.

6. What is an asset?

An asset is anything valuable that an organization needs to protect, such as data, applications, servers, devices, accounts, credentials, systems, or business information.

7. What is a threat?

A threat is a potential event, actor, or action that can exploit a vulnerability and cause harm to an asset. Examples include attackers, malware, phishing, and unauthorized actions.

8. What is identification?

Identification is the process by which a user or system claims an identity, such as entering a username, email address, or user ID. It answers the question: "Who are you?"

9. What is authentication?

Authentication is the process of verifying that a claimed identity is genuine. It may use passwords, OTPs, biometrics, security keys, or multiple factors.

10. Explain Authorization.

Authorization determines what an authenticated user or system is allowed to access or perform. For example, an administrator may be authorized to delete users, while a normal user may only view their own profile.

11. What is the difference between Authentication and Authorization?

Authentication verifies identity — “Who are you?” Authorization determines permissions — “What are you allowed to do?” Authentication normally happens before authorization.

12. A01:2025 — Broken Access Control

Broken Access Control occurs when an application fails to properly enforce what users are allowed to access or do. It can allow users to view, modify, or delete resources beyond their intended permissions.

13. A02:2025 — Security Misconfiguration

Security Misconfiguration means security settings are missing, insecure, or incorrectly configured, such as unnecessary services, default credentials, verbose error messages, or improperly configured cloud resources.

14. A03:2025 — Software Supply Chain Failures

Software Supply Chain Failures occur when vulnerabilities or compromises in third-party libraries, packages, dependencies, build systems, or development tools affect an application. Organizations should track dependencies and verify their integrity and security.

15. A04:2025 — Cryptographic Failures

Cryptographic Failures happen when sensitive information is not adequately protected through encryption or when weak, outdated, or incorrectly implemented cryptography is used. This can expose passwords, personal data, or other confidential information.

16. A05:2025 — Injection

Injection occurs when untrusted input is interpreted as part of a command or query by an interpreter. Examples include SQL injection, command injection, and other forms of injection.

17. A06:2025 — Insecure Design

Insecure Design refers to security weaknesses introduced at the design or architecture stage because security requirements and threat scenarios were not adequately considered. Secure design requires appropriate security controls to be planned before implementation.

18. A07:2025 — Authentication Failures

Authentication Failures occur when an application incorrectly handles identity verification, allowing attackers to guess, bypass, or abuse authentication mechanisms. Weak passwords, poor session handling, and missing protections against automated attacks are examples.

19. A08:2025 — Software or Data Integrity Failures

Software or Data Integrity Failures occur when an application trusts software, updates, plugins, serialized data, or other information without adequately verifying its integrity and authenticity. This can allow unauthorized or malicious changes to be accepted.

20. A09:2025 — Security Logging and Alerting Failures

These failures occur when important security events are not logged, monitored, or alerted properly. Poor logging and alerting can delay detection, investigation, and response to attacks.

21. A10:2025 — Mishandling of Exceptional Conditions

Mishandling of Exceptional Conditions occurs when applications do not safely handle errors, unexpected inputs, resource failures, or unusual states. Poor error handling can cause information disclosure, insecure behavior, crashes, or other security problems.